เอกสารประกอบการปฏิบัติการ
รายวิชา CP423324 Database and Web Security
Lab 3: พื้นฐาน PHP สำหรับ Web Application

วัตถุประสงค์

1. เพื่อให้นักศึกษาสามารถเขียน PHP พื้นฐาน เช่น ตัวแปร เงื่อนไข และฟังก์ชันได้
2. เพื่อให้นักศึกษาสามารถรับค่าจาก HTML Form ด้วย $_GET และ $_POST ได้
3. เพื่อให้นักศึกษาสามารถตรวจสอบค่าว่างของข้อมูลที่ผู้ใช้ส่งมาจาก Form ได้
4. เพื่อให้นักศึกษาสามารถแสดงผลข้อมูลที่รับมาจาก Form อย่างปลอดภัยเบื้องต้นได้

คำชี้แจง

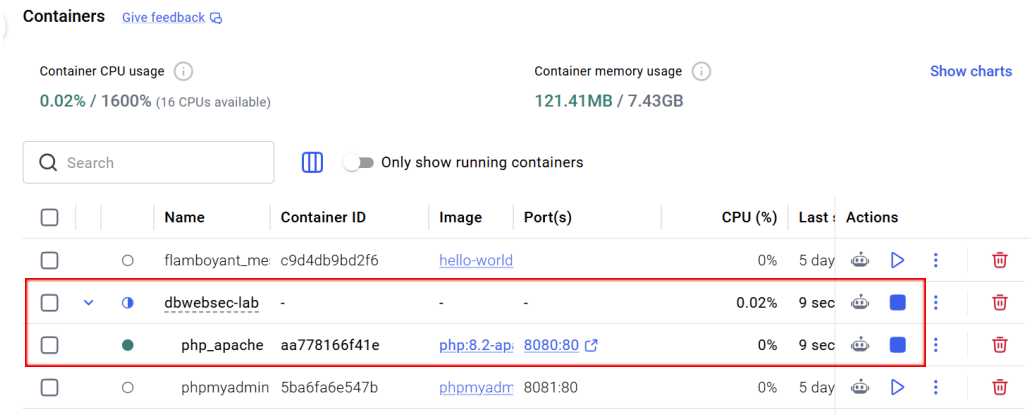
1. **ให้นักศึกษา** Capture **ผลลัพท์ตามที่งานของแต่ละข้อกำหนดลงใน Word และบันทึกไฟล์เป็น PDF โดยให้ตั้งชื่อว่า Lab03_รหัสนักศึกษา(มีขีด).pdf**
2. **เมื่อทำเสร็จเรียบร้อยแล้วให้แจ้งผู้ช่วยสอน (TA) เพื่อทำให้การขอตรวจ และตอบคำถาม (กรุณาตรวจกับพี่ TA โดยคะแนนจะมาจากการตรวจในห้องเรียน)**
3. **เมื่อตรวจกับ TA เรียบร้อยแล้วให้นักศึกษาส่งใน Classroom เพื่อเป็นการสำรองข้อมูล**
4. **ไม่อนุญาตให้ส่งงานย้อนหลังได้ ยกเว้นกรณีลาป่วย หรืออุบัติเหตุ (ต้องมีใบรับรองแพทย์)**

★★★★★★★★★

โจทย์ที่กำหนด

1. ให้นักศึกษาสร้างโฟลเดอร์ Lab03 ไว้ภายใน C:\dbwebsec-lab\www

2. จากนั้นเปิด docker ที่เคยสร้างไว้ ให้ Start container name: dbwebsec-lab และ php_apache



3. ให้สร้างไฟล์จำนวน 3 ไฟล์ ได้แก่ Lab03_index.php, Lab03_process.php และ Lab03_config.php ภายในโฟลเดอร์ Lab03

1) Lab03_index.php

แสดงหน้าเว็บและ Form สำหรับกรอกข้อมูล โดยมีทั้ง Search Form แบบ GET และ Contact Form แบบ POST

2) Lab03_process.php

รับค่าจาก Form ตรวจสอบค่าว่าง แยกการทำงานตาม GET/POST และแสดงผลข้อมูล

3) Lab03_config.php

เก็บค่ากำหนดพื้นฐานของระบบ และฟังก์ชันที่ใช้ซ้ำ เช่น ฟังก์ชัน h() สำหรับแสดงผลข้อมูลอย่างปลอดภัย

3.1 ให้สร้างไฟล์ชื่อ Lab03_config.php เพื่อเก็บค่ากำหนดของระบบและฟังก์ชันที่ใช้ซ้ำ โดยไฟล์นี้จะถูกเรียกใช้จาก Lab03_index.php และ Lab03_process.php

```php
<?php
$web_name = "PHP Form Processing Lab";

function is_blank($value) {
    return trim($value ?? '') === '';
}

?>
```

3.2 ให้สร้างไฟล์ชื่อ Lab03_index.php เพื่อแสดง Form จำนวน 2 ส่วน คือ Search Form ที่ใช้ GET และ Contact Form ที่ใช้ POST และตกแต่งด้วย CSS ให้สวยงาม

กำหนดให้ Lab03_index.php มีหน้าจอสำหรับกรอกข้อมูลดังนี้

ส่วนที่ 1 Search Form ส่งข้อมูลไปยัง Lab03_process.php ด้วย method="get"

รายการ	input type	name	ข้อกำหนด	รายละเอียด / value
Keyword	search	keyword	ต้องกรอกข้อมูล และจำกัดความยาวไม่เกิน 50 ตัวอักษร	กรอกคำค้นหา เช่น php, html, security
Category	select	category	ต้องเลือกหมวดหมู่	มีตัวเลือก php, html, security
ปุ่ม Search	submit	-	-	ใช้ส่งข้อมูล
ปุ่ม Reset	reset	-	-	ใช้ล้างข้อมูลในฟอร์ม

ส่วนที่ 2 Contact Form ส่งข้อมูลไปยัง Lab03_process.php ด้วย method="post"

รายการ	input type	name	ข้อกำหนด	รายละเอียด / value
Full Name	text	fullname	ต้องกรอกข้อมูล และจำกัดความยาวไม่เกิน 50 ตัวอักษร	กรอกชื่อ-นามสกุล
Email	email	email	ต้องกรอกข้อมูล และตรวจสอบรูปแบบอีเมลเบื้องต้น	กรอกอีเมล
Subject	text	subject	ต้องกรอกข้อมูล และจำกัดความยาวไม่เกิน 100 ตัวอักษร	กรอกหัวข้อเรื่องที่ต้องการติดต่อ

รายการ	input type	name	ข้อกำหนด	รายละเอียด / value
Message	textarea	message	ต้องกรอกข้อมูล ความยาวอย่างน้อย 10 ตัวอักษร และไม่เกิน 500 ตัวอักษร	กรอกรายละเอียดข้อความหรือคำถาม
Contact Type	radio	contact_type	ต้องเลือกค่าใดค่าหนึ่ง	มี 3 ตัวเลือก คือ question, problem, suggestion
ปุ่ม Send Message	submit	-	-	ใช้ส่งข้อมูล
ปุ่ม Reset	reset	-	-	ใช้ล้างข้อมูลในฟอร์ม

หมายเหตุ: หน้า Lab03_index.php ประกอบด้วย Form จำนวน 2 ส่วน ได้แก่ Search Form ที่ส่งข้อมูลด้วย GET และ Contact Form ที่ส่งข้อมูลด้วย POST โดยทั้งสอง Form ส่งข้อมูลไปยังไฟล์ Lab03_process.php เพื่อประมวลผลต่อไป

```php
<?php require_once 'Lab03_config.php'; ?>
<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <title><?php echo $web_name; ?></title>

  <style>
    body {font-family: Arial, sans-serif; background-color: #eef7f3;padding: 30px; }
    .container { width: 760px; margin: auto; }
    .form-box { background: white;padding: 20px; margin-bottom: 20px; border-radius: 10px;}
    label { display: block; margin-top: 10px; font-weight: bold; }
    input[type="text"], input[type="email"], input[type="search"], select,
    textarea { width: 100%; padding: 8px; box-sizing: border-box; }
    .role-group { margin-top: 10px; margin-bottom: 15px; }
    .role-group input[type="radio"] { width: auto; margin-right: 5px;}
    .role-group label { display: inline; font-weight: normal; margin-right: 15px; }
    input[type="submit"], input[type="reset"] { width: auto; padding: 8px 16px; margin-top: 15px;}
  </style>
</head>

<body>
  <div class="container">
    <h1><?php echo $web_name; ?></h1>

    <div class="form-box">
      <h2>Search Form (GET)</h2>

      <form action="Lab03_process.php" method="get">
        <label for="keyword">Keyword:</label>
        <input type="search" id="keyword" name="keyword" placeholder="Enter keyword" required maxlength="50">

        <label for="category">Category:</label>
        <select id="category" name="category" required>
          <option value="">-- Select Category --</option>
          <option value="php">PHP</option>
          <option value="html">HTML</option>
          <option value="css">CSS</option>
        </select>

        <input type="submit" value="Search">
        <input type="reset" value="Reset">
      </form>
    </div>

```

```
    <div class="form-box">
      <h2>Contact Form (POST)</h2>

      <form action="Lab03_process.php" method="post">
        <label for="fullname">Full Name:</label>
        <input type="text" id="fullname" name="fullname" required maxlength="50">

        <label for="email">Email:</label>
        <input type="email" id="email" name="email" required>

        <label for="subject">Subject:</label>
        <input type="text" id="subject" name="subject" required maxlength="100">

        <label for="message">Message:</label>
        <textarea id="message" name="message" rows="5" required minlength="10" maxlength="500"></textarea>

        <p><strong>Contact Type:</strong></p>
        <div class="role-group">
          <input type="radio" id="question" name="contact_type" value="question" required>
          <label for="question">Question</label>

          <input type="radio" id="problem" name="contact_type" value="problem">
          <label for="problem">Problem Report</label>

          <input type="radio" id="suggestion" name="contact_type" value="suggestion">
          <label for="suggestion">Suggestion</label>
        </div>

        <input type="submit" value="Send Message">
        <input type="reset" value="Reset">
      </form>
    </div>
  </div>
</body>
</html>
```

3.3 ให้สร้างไฟล์ชื่อ Lab03_process.php เพื่อแยกการทำงานตาม Request Method และตรวจสอบข้อมูลที่ได้รับจาก Form

```php
<?php
require_once 'Lab03_config.php';

$method = $_SERVER['REQUEST_METHOD'];
$errors = [];
$result_title = '';
$result_data = [];

if ($method === 'GET') {
    $keyword = trim($_GET['keyword'] ?? '');
    $category = trim($_GET['category'] ?? '');

    if (is_blank($keyword)) {
        $errors[] = 'Keyword is required.';
    } elseif (strlen($keyword) > 50) {
        $errors[] = 'Keyword must not exceed 50 characters.';
    }

    if (is_blank($category)) {
        $errors[] = 'Category is required.';
    } elseif (!in_array($category, ['php', 'html', 'css', 'security'])) {
        $errors[] = 'Invalid category.';
    }

```

```php
    $result_title = 'Search Result';
    $result_data = [
        'Keyword' => $keyword,
        'Category' => $category
    ];
} elseif ($method === 'POST') {
    $fullname = trim($_POST['fullname'] ?? '');
    $email = trim($_POST['email'] ?? '');
    $subject = trim($_POST['subject'] ?? '');
    $message = trim($_POST['message'] ?? '');
    $contact_type = trim($_POST['contact_type'] ?? '');

    if (is_blank($fullname)) {
        $errors[] = 'Full Name is required.';
    } elseif (strlen($fullname) > 50) {
        $errors[] = 'Full Name must not exceed 50 characters.';
    }

    if (is_blank($email)) {
        $errors[] = 'Email is required.';
    } elseif (!filter_var($email, FILTER_VALIDATE_EMAIL)) {
        $errors[] = 'Invalid email format.';
    }

    if (is_blank($subject)) {
        $errors[] = 'Subject is required.';
    } elseif (strlen($subject) > 100) {
        $errors[] = 'Subject must not exceed 100 characters.';
    }

    if (is_blank($message)) {
        $errors[] = 'Message is required.';
    } elseif (strlen($message) < 10) {
        $errors[] = 'Message must be at least 10 characters.';
    } elseif (strlen($message) > 500) {
        $errors[] = 'Message must not exceed 500 characters.';
    }

    if (is_blank($contact_type)) {
        $errors[] = 'Contact Type is required.';
    } elseif (!in_array($contact_type, ['question', 'problem', 'suggestion'])) {
        $errors[] = 'Invalid Contact Type.';
    }

    $result_title = 'Contact Form Result';
    $result_data = [
        'Full Name' => $fullname,
        'Email' => $email,
        'Subject' => $subject,
        'Message' => $message,
        'Contact Type' => $contact_type
    ];
}
?>
```

```
<!DOCTYPE html>
<html lang="en">
<head>
  <meta charset="UTF-8">
  <title><?php echo $result_title; ?></title>
  <style>
    body { font-family: Arial, sans-serif; background-color: #eef7f3; padding: 30px; }
    .box { width: 760px; margin: auto; background: white; padding: 20px; border-radius: 10px; }
    .error { color: #b00020; background: #ffe6e6; padding: 10px; border-radius: 5px; }
    table { width: 100%; border-collapse: collapse; margin-top: 15px; }
    th, td { border: 1px solid #ccc; padding: 8px; text-align: left; }
    th { background: #d9ead3; }
  </style>
</head>
<body>
  <div class="box">
    <h1><?php echo $result_title; ?></h1>
    <p>Request Method: <strong><?php echo $method; ?></strong></p>

    <?php if (!empty($errors)): ?>
      <div class="error">
        <strong>Please check the following errors:</strong>
        <ul>
          <?php foreach ($errors as $error): ?>
            <li><?php echo $error; ?></li>
          <?php endforeach; ?>
        </ul>
      </div>
    <?php else: ?>

      <table>
        <tr>
          <th>Field</th>
          <th>Value</th>
        </tr>
        <?php foreach ($result_data as $field => $value): ?>
          <tr>
            <td><?php echo $field; ?></td>
            <td><?php echo $value; ?></td>
          </tr>
        <?php endforeach; ?>
      </table>
    <?php endif; ?>

    <p><a href="Lab03_index.php">Back to Form</a></p>
  </div>
</body>
</html>
```

งานที่ 1.1 ให้เปิด Browser แล้วพิมพ์ URL: http://localhost:8080/Lab03/ Lab03_index.php จากนั้น Capture หน้าเว็บ

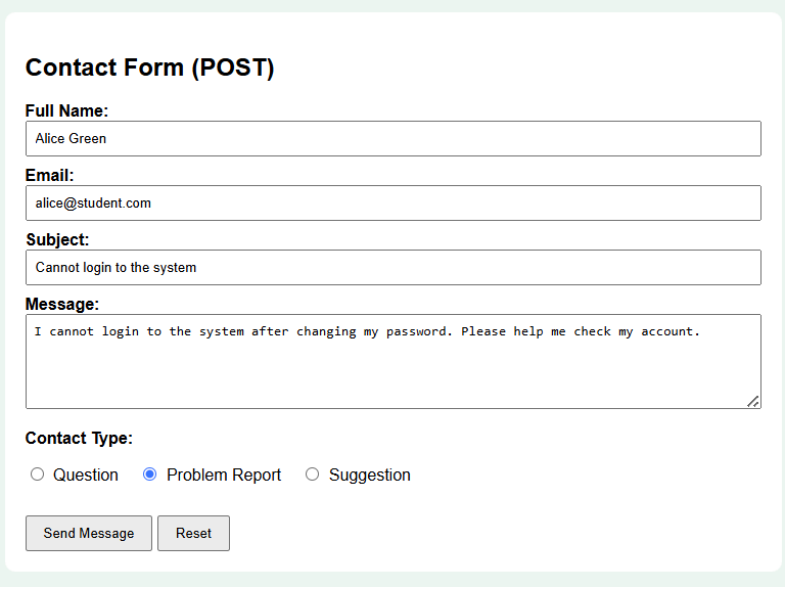
งานที่ 1.2 Capture URL เมื่อกรอกข้อมูล Search Form เช่น Keyword = Form และ Category = HTML และ Capture หน้าแสดงผลเมื่อกดปุ่ม Search

ตัวอย่างการกรอกข้อมูล



งานที่ 1.3 เปิด Browser DevTools แท็บ Network และตรวจสอบ Query String Parameters ให้ Capture Payload

งานที่ 2.1 ให้เปิด Browser แล้วพิมพ์ URL: http://localhost:8080/Lab03/ Lab03_index.php กรอก Contact Form ให้ครบถ้วน เช่น Full Name, Email, Subject, Message และ Contact Type กดปุ่ม Send Message จากนั้น Capture URL และหน้าแสดงผลจาก Lab03_process.php
ตัวอย่างการกรอกข้อมูล



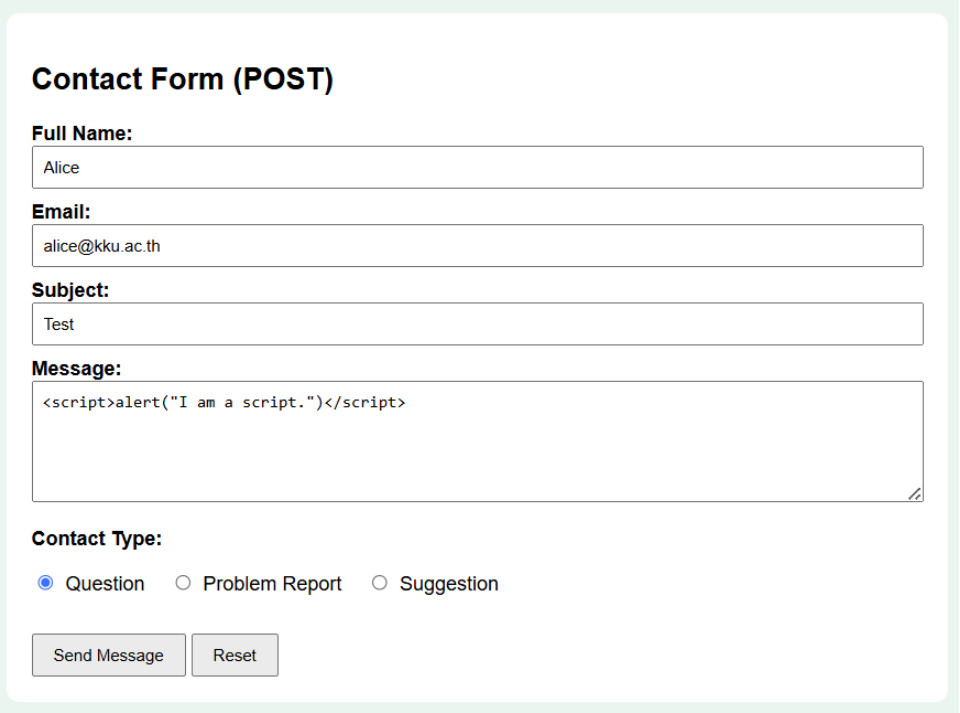
งานที่ 2.2 เปิด Browser DevTools แท็บ Network และตรวจสอบ Query String Parameters ให้ Capture Query String Parameters

งานที่ 3.1: ให้นักศึกษาไปที่ Search Form แล้วพิมพ์ช่องว่าง (กดปุ่ม Spacebar) ในช่อง Keyword แล้วเลือก Category แล้วกดปุ่ม Search จากนั้นให้ Capture Capture URL และหน้าจอผลลัพธ์ของการ Search
ตัวอย่างการกรอกข้อมูล



งานที่ 3.2: ให้นักศึกษาไปที่ Contact Form แล้วกรอกข้อมูลที่มีอักขระพิเศษ เช่น Alice หรือ <script>alert("I am a script.")</script> ในช่อง Message ของ Contact Form แล้วกดปุ่ม Send Message จากนั้นให้ Capture หน้าจอผลลัพธ์

ตัวอย่างการกรอกข้อมูล



งานที่ 3.3: ให้นักศึกษาแก้ไขคำสั่งเพื่อผู้ใช้กรอกข้อมูลที่มีอักขระพิเศษ เช่น Alice หรือ <script>alert("I am a script.")</script> ในช่อง Message ของ Contact Form ต้องถูกแสดงเป็นข้อความ ไม่ควรถูกตีความเป็น HTML หรือ JavaScript

ให้นักศึกษาให้ Capture หน้าจอผลลัพธ์จากการแก้ไขคำสั่งแล้ว